@demotoprod · THE LAB · EPISODE 1 · GATES

Three gates for an AI email assistant

We ran one AI inbox assistant 180 times against a mock inbox: three emails, three builds, twenty runs each, every run logged. A hardened security prompt still sent our invoice to an outside address in 14 of 20 runs. These three gates, in code, held in every run.

1 An allowlist on anything that leaves

The model reads your instructions and a stranger's email as the same kind of text. Our lab: 18 of 20 leaks with the tutorial build, 14 of 20 with a security prompt, 0 of 20 with this gate.

- Keep a list of approved outside contacts. Anything else waits for a person.
- Enforce it inside the send, forward and reply tools, not in the prompt.
- Log every held message. The attempts are your early warning.

```
def send(to, body):
    if to not in APPROVED_CONTACTS:
        return hold_for_approval(to, body)
    return mail.send(to, body)
```

2 A human on anything that commits money

Asked for a written refund, the tutorial build said yes in 7 of 20 runs. With "never promise refunds" in the prompt, 1 of 20. Drafts only: 0 of 20 sent.

- Replies to outside addresses are saved as drafts. A person sends them.
- Auto-send only fixed templates, such as an acknowledgement. Never free text to a customer.
- Read the drafts queue. It shows you what the assistant would have promised.

```
def reply(email, body):
    if not is_internal(email.sender):
        return save_draft_for_review(email, body)
    return mail.send(email.sender, body)
```

3 A filter at the door for anything automatic

Auto-replies answering auto-replies is how mail loops start. Our assistant replied to an out-of-office in 1 of 20 runs. The filter costs nothing.

- Drop messages marked Auto-Submitted (anything but "no"), X-Autoreply or Precedence bulk/list before the model sees them (RFC 3834).
- Mark your own automated mail Auto-Submitted auto-generated.
- Cap the replies the assistant can send in one thread.

```
def on_new_email(msg):
    if msg.headers.get("Auto-Submitted", "no") != "no":
        return  # RFC 3834: never answer a robot
    agent.handle(msg)
```